

INFORME DE RESPUESTA A INCIDENTES

Trickbot Infection – Active Directory Environment

Autor: Nicolás Sotomayor

Rol: SOC Analyst (Junior)

Fecha: Mayo 2026

LinkedIn: [linkedin.com/in/nikosotomayor-cyber](https://www.linkedin.com/in/nikosotomayor-cyber)

GitHub: github.com/nicosotomayor

Índice

1. Resumen Ejecutivo	3
2. Fuente del Caso.....	3
3. Alcance del Análisis	3
4. Metodología	4
5. Timeline del Incidente	4
6. Análisis Técnico	4
7. Indicadores de Compromiso (IoCs)	6
8. Técnicas MITRE ATT&CK.....	7
9. Validación de Malware mediante VirusTotal	7
10. Evaluación de Impacto.....	8
11. Recomendaciones	8
12. Conclusión.....	9

1. Resumen Ejecutivo

Se realizó el análisis del archivo de tráfico de red 2020-05-28-traffic-analysis-exercise.pcap, donde se identificó una infección activa de malware tipo **Trickbot** en un entorno corporativo basado en Active Directory.

El incidente se originó a partir de un endpoint comprometido, el cual estableció comunicaciones con infraestructura de comando y control (C2) mediante solicitudes HTTP POST. Durante el análisis se evidenció una cadena completa de compromiso, incluyendo exfiltración de credenciales y movimiento lateral exitoso hacia el Domain Controller.

Este comportamiento representa un incidente de **críticidad alta**, ya que implica la posible pérdida de control total del dominio y acceso a información sensible.

2. Fuente del Caso

Ejercicio basado en:

<https://www.malware-traffic-analysis.net/2020/05/28/index.html>

Fecha: 28 de mayo de 2020

Autor: Brad Duncan (Unit 42)

Archivo analizado:

2020-05-28-traffic-analysis-exercise.pcap

3. Alcance del Análisis

- **Rango de red:** 10.5.28.0/24
- **Dominio:** catbomber.net
- **Domain Controller:** 10.5.28.8 (CATBOMBER-DC)

Objetivos del análisis:

- Identificar el host comprometido
- Detectar actividad maliciosa

- Determinar credenciales comprometidas
 - Identificar artefactos maliciosos
 - Evaluar el impacto del incidente
-

4. Metodología

El análisis fue realizado utilizando herramientas de análisis de tráfico de red como **TShark**, aplicando un enfoque estructurado de análisis forense:

- Identificación de tráfico anómalo
 - Filtrado de solicitudes HTTP POST
 - Inspección de payloads
 - Extracción de objetos HTTP
 - Análisis de cadenas (strings)
 - Generación de hashes criptográficos
-

5. Timeline del Incidente

Se reconstruyó la secuencia del ataque en base al tráfico observado:

1. **Compromiso inicial**
Infección del host 10.5.28.229 (Windows 7)
 2. **Comunicación C2**
Envío de solicitudes HTTP POST hacia infraestructura externa
 3. **Exfiltración de credenciales**
Transmisión de credenciales de correo en texto plano
 4. **Movimiento lateral**
Acceso al Domain Controller utilizando credenciales comprometidas
 5. **Entrega de malware**
Transferencia de ejecutables disfrazados como archivos legítimos
-

6. Análisis Técnico

6.1 Host comprometido

Se identificó un host interno que genera tráfico HTTP POST repetitivo.

Resultado:

- **IP:** 10.5.28.229
- **Hostname:** CAT-BOMB-W7-PC
- **Usuario:** yas33

Evidencia:

POST /yas33/CAT-BOMB-W7-PC_...

Interpretación:

El formato /usuario/hostname es característico de comunicaciones de Trickbot.

6.2 Comunicación con infraestructura C2

El host comprometido se comunica con:

- 36.89.106.69
- 203.176.135.102:8082

Interpretación:

Este tráfico corresponde a servidores de comando y control utilizados para gestionar el malware.

6.3 Movimiento lateral

Se detectó actividad desde el Domain Controller.

Resultado:

- **Usuario:** jim734
- **Hostname:** CATBOMBER-DC

Evidencia:

POST /jim734/CATBOMBER-DC_...

Interpretación:

Se confirma propagación del malware dentro del dominio y compromiso de infraestructura crítica.

6.4 Exfiltración de credenciales

Se identificaron credenciales en texto plano.

Resultado:

- **Usuario:** phillip.ghent
- **Contraseña:** gh3ntf@st

Evidencia:

pop3://mail.catbomber.net:995|phillip.ghent|gh3ntf@st

Interpretación:

El malware recolecta credenciales mediante protocolos de correo (POP3).

6.5 Archivos maliciosos

Se detectaron archivos ejecutables dentro del tráfico HTTP.

Resultado:

- cursor.png → ejecutable Windows (PE32)
- imgpaper.png → ejecutable Windows (PE32)

Interpretación:

Los archivos están disfrazados como imágenes, técnica de evasión conocida.

6.6 Hashes SHA256

- 4e76d73f3b303e481036ada80c2eeba8db2f306cbc9323748560843c80b2fed1
 - 934c84524389ecfb3b1dfcb28f9697a2b52ea0ebcaa510469f0d2d9086bcc79a
-

7. Indicadores de Compromiso (IoCs)

Host comprometido:

- 10.5.28.229

Infraestructura externa:

- 36.89.106.69
- 203.176.135.102

Credenciales comprometidas:

- phillip.ghent / gh3ntf@st

Archivos maliciosos:

- cursor.png
- imgpaper.png

Hashes:

- 4e76d73f3b303e481036ada80c2eeba8db2f306cbc9323748560843c80b2fed1
 - 934c84524389ecfb3b1dfcb28f9697a2b52ea0ebcaa510469f0d2d9086bcc79a
-

8. Técnicas MITRE ATT&CK

- **T1071.001** – Command and Control over HTTP
 - **T1003** – Credential Dumping
 - **T1021** – Lateral Movement
 - **T1041** – Exfiltration Over Network
 - **T1036** – Masquerading
-

9. Validación de Malware mediante VirusTotal

Con el objetivo de validar la naturaleza maliciosa de los archivos identificados durante el análisis, se realizó la consulta de los hashes SHA256 en la plataforma de inteligencia de amenazas VirusTotal

9.1 Análisis del archivo cursor.png

- **SHA256:**
4e76d73f3b303e481036ada80c2eeba8db2f306cbc9323748560843c80b2fed1
- **Detección:** 62/72 motores antivirus lo identifican como malicioso
- **Clasificación:** Trojan / Malware Loader
- **Familias detectadas:** Emotet, Agent, Mansabo

Figura 10 – Resultado del análisis en VirusTotal para el archivo cursor.png

9.2 Análisis del archivo imgpaper.png

- **SHA256:**
934c84524389ecfb3b1dfcb28f9697a2b52ea0ebcaa510469f0d2d9086bc
c79a
- **Detección:** 61/72 motores antivirus lo identifican como malicioso
- **Clasificación:** Trojan
- **Familias detectadas:** Emotet, Agent, Mansabo

Figura 11 – Resultado del análisis en VirusTotal para el archivo imgpaper.png

9.3 Interpretación

Los resultados obtenidos confirman que ambos archivos corresponden a **malware real ampliamente detectado por múltiples motores antivirus**, lo que valida el análisis realizado sobre el tráfico de red.

La coincidencia en las familias de malware detectadas refuerza la hipótesis de que los archivos forman parte de una misma cadena de infección asociada a campañas de tipo **banking trojan / loader**, como Trickbot o variantes relacionadas.

10. Evaluación de Impacto

El incidente presenta un nivel de criticidad **alto**, debido a:

- Compromiso de credenciales
- Acceso al Domain Controller
- Posible control total del dominio
- Riesgo de persistencia del atacante
- Potencial despliegue de ransomware

El compromiso del Domain Controller podría permitir al atacante escalar privilegios, distribuir malware adicional y afectar la continuidad operativa del negocio

11. Recomendaciones

- Aislar el host comprometido (10.5.28.229)

- Resetear todas las credenciales afectadas
 - Auditar el Domain Controller
 - Bloquear las direcciones IP identificadas
 - Implementar monitoreo de tráfico HTTP anómalo
 - Desplegar soluciones EDR
 - Revisar logs de autenticación
-

12. Conclusión

El análisis evidencia una cadena completa de ataque, desde la infección inicial hasta el compromiso del Domain Controller, lo que implica un riesgo crítico para la organización.

La capacidad del malware para robar credenciales, moverse lateralmente y comunicarse con infraestructura externa confirma la presencia de una amenaza avanzada dentro del entorno.

Este análisis demuestra la capacidad de identificar, investigar y documentar incidentes de seguridad en entornos corporativos.